INFORME DE VULNERABILIDADES

Aplicación Android MapGps

Análisis estático y dinámico con MobSF

Dato	Valor
Aplicación	Rumbo · Bitácora (APK de depuración)
Paquete	com.example.mapgps
APK	app-debug.apk · 15,01 MB
MD5	50938cedc415a82a7e03b39c204c51e8
SHA-256	9986aa1d08d05cbdb35a7ad4162c866decc8d8a74c0c89b0fa4e984b83ee51ad
Herramienta	MobSF v4.6.2
Fecha/hora	27 oct 2026, 00:49 estático / 00:23 dinámico (según MobSF)

Resumen ejecutivo

El análisis estático asignó 44/100 (riesgo medio, calificación B) e informó dos alertas altas y dos advertencias de configuración. En la prueba dinámica se recorrieron funciones básicas en un emulador y no se detectaron trackers. MobSF dejó las pruebas específicas TLS como “Not Tested”; por ello no se concluye que toda la comunicación sea segura.

Prioridad	Resultado	Lectura
Alta (2)	Certificado Android Debug; android:debuggable=true	Corregir antes de publicar.
Advertencia (2)	allowBackup=true; receiver AndroidX exportado protegido por DUMP	Revisar configuración.
Dinámico	Sin vulnerabilidad nueva confirmada en el recorrido	El alcance fue limitado.
Contextual	Permisos de ubicación/cámara y cadena candidata en DEX	No son vulnerabilidades confirmadas por sí solos.

1. Análisis estático

MobSF examinó el APK sin ejecutarlo. Las severidades son las asignadas por la herramienta; la evaluación y recomendación se detallan aquí.

Hallazgo	Severidad MobSF	Evaluación y recomendación
Certificado Android Debug	Alta	Es una firma de depuración. No distribuir como versión final; generar APK release con certificado de producción y resguardar su clave.
android:debuggable=true	Alta	Facilita depuración e inspección del proceso. Confirmar debuggable=false en la variante release y revisar el manifiesto final.
android:allowBackup=true	Advertencia	Puede permitir respaldo de datos según plataforma/configuración. Excluir ubicaciones y referencias de fotos; desactivar backup si no se necesita.
ProfileInstallReceiver exportado	Advertencia	MobSF pide verificar android.permission.DUMP. Revisar protectionLevel y necesidad; restringir/deshabilitar si no se requiere.

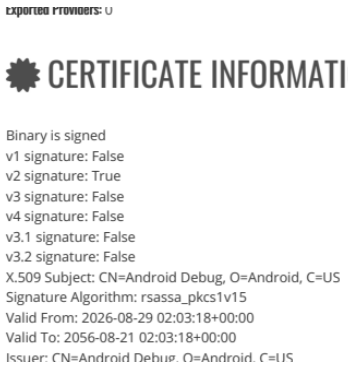


Figura 2. MobSF identifica un certificado Android Debug.

TITLE	SEVERITY	DESCRIPTION
Signed Application	info	Application is signed with a code signing certificate
Application signed with debug certificate	high	Application signed with a debug certificate. Production application must not be shipped with a debug certificate.

MANIFEST ANALYSIS

HIGH: 1 | WARNING: 2 | INFO: 0 | SUPPRESSED: 0

NO	ISSUE	SEVERITY	DESCRIPTION
1	Debug Enabled For App [android:debuggable=true]	high	Debugging was enabled on the app which makes it easier for reverse engineers to hook a debugger to it. This allows dumping a stack trace and accessing debugging helper classes.
2	Application Data can be Backed up [android:allowBackup=true]	warning	This flag allows anyone to backup your application data via adb. It allows users who have enabled USB debugging to copy application data off of the device.
3	Broadcast Receiver (androidx.profileinstaller.ProfileInstallReceiver) is Protected by a permission, but the protection level of the permission should be checked. Permission: android.permission.DUMP [android:exported=true]	warning	A Broadcast Receiver is found to be shared with other apps on the device therefore leaving it accessible to any other application on the device. It is protected by a permission which is not defined in the analysed application. As a result, the protection level of the permission should be checked where it is defined. If it is set to normal or dangerous, a malicious application can request and obtain the permission and interact with the component. If it is set to signature, only applications signed with the same certificate can obtain the permission.

Figura 3. Alertas detectadas en el manifiesto.

2. Permisos y datos locales

Ubicación aproximada/precisa y cámara son coherentes con mostrar el mapa y tomar fotografías. MobSF las clasifica como permisos sensibles (“dangerous”); esa clasificación no significa por sí sola que exista una vulnerabilidad. Solicitarlos al usuario solo cuando se necesiten.

APPLICATION PERMISSIONS

PERMISSION	STATUS	INFO	DESCRIPTION
android.permission.ACCESS_FINE_LOCATION	dangerous	fine (GPS) location	Access fine location sources, such as the Global Positioning System on the phone, where available. Malicious applications can use this to determine where you are and may consume additional battery power.
android.permission.ACCESS_COARSE_LOCATION	dangerous	coarse (network-based) location	Access coarse location sources, such as the mobile network database, to determine an approximate phone location, where available. Malicious applications can use this to determine approximately where you are.
android.permission.CAMERA	dangerous	take pictures and videos	Allows application to take pictures and videos with the camera. This allows the application to collect images that the camera is seeing at any time.
android.permission.ACCESS_NETWORK_STATE	normal	view network status	Allows an application to view the status of all networks.

Figura 4. Permisos declarados por el APK.

El análisis estático identifica lectura/escritura de archivos y serialización de ubicación a JSON en MainActivity. La revisión del código indica que los lugares y referencias de fotos se guardan en almacenamiento interno privado; no se observó envío de estos registros a un servidor propio. Por allowBackup=true, conviene excluir esos datos de respaldos si contienen información personal.

MobSF señaló una cadena hexadecimal de alta entropía en DEX como posible secreto. No se validó como credencial ni se pudo atribuir su uso; se omite el valor por seguridad. Rastrear su origen en código/dependencias y rotarlo solo si se confirma que es una credencial.

BEHAVIOUR ANALYSIS

RULE ID	BEHAVIOUR	LABEL	FILES
00014	Read file into a stream and put it into a JSON object	file	com/example/mapgps/MainActivity.java
00013	Read file and put it into a stream	file	com/example/mapgps/MainActivity.java
00016	Get location info of the device and put it to JSON object	location collection	com/example/mapgps/MainActivity.java

HARDCODED SECRETS

POSSIBLE SECRETS
Valor omitido en el informe por no estar validado como credencial.

Figura 5. Reglas de comportamiento y posible secreto; valor oculto.

Las señales de ofuscación y referencias a propiedades del dispositivo son heurísticas; no demuestran por sí solas actividad maliciosa.

3. Análisis dinámico

Parámetro	Detalle
Entorno	Emulador Pixel 5, Android 11 / API 30, x86; MobSF v4.6.2 con Frida.
Recorrido	Inicio, permiso de ubicación en emulador, mapa, marcador, apertura de cámara y foto de prueba.
APK	MD5/SHA-256 coinciden con el análisis estático. No se probó el teléfono físico.
Alcance	Solo cubre el recorrido observado; no todos los estados, dispositivos o redes.

Área	Resultado	Interpretación
Red	56 eventos getInputStream; llamadas visibles incluyen clases HTTPS/OkHttp.	No se confirmó HTTP claro en evidencia revisada. Pruebas TLS no ejecutadas.
Dominios	14 entradas con estado “good”; sin OFAC.	Clasificación MobSF, no auditoría completa de servicios.
Trackers	No reportados en la tabla.	No detectados en esta prueba; no prueba ausencia absoluta.
File I/O	97 eventos; operaciones visibles incluyen Maps SDK y escritura privada modo 0.	No se extrajeron bases SQLite/XML ni otros datos de la app.
Hash/Base64	83 llamadas hash y una cadena Base64 decodificada.	No se obtuvo evidencia de secreto legible.
TLS	Pruebas cleartext, configuración TLS y pinning: Not Tested.	No hay conclusión dinámica sobre estos controles.



Figura 6. Eventos HTTPS, dominios y tabla de trackers.

4. Evidencia y conclusión

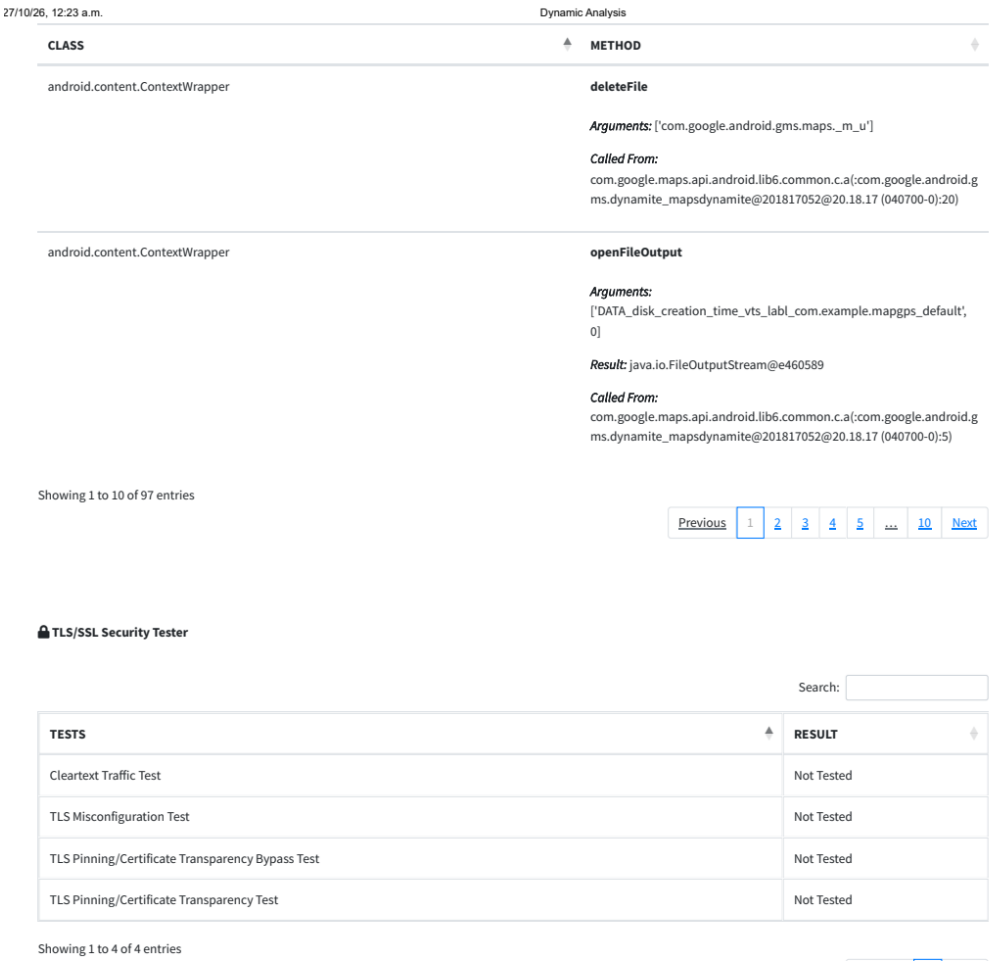


Figura 7. File I/O observado y pruebas TLS marcadas "Not Tested".

Conclusiones

El APK es una compilación de depuración y debe prepararse una variante release antes de distribuirlo. Las alertas de backup y del receiver requieren revisión. Permisos y comportamiento de ubicación/archivos se interpretan según la función de la app. En la ejecución dinámica no se confirmó exfiltración de lugares/fotos ni una vulnerabilidad nueva, dentro del alcance acotado.

TLS no está validado: sus pruebas quedaron "Not Tested". La ausencia de trackers o de dominios con mala reputación tampoco garantiza seguridad total.

Acciones recomendadas

- Generar y revisar APK release: firma de producción, debuggable=false y manifiesto final.
- Definir política de backup y excluir archivos con coordenadas, lugares y referencias de fotos cuando corresponda.
- Verificar protectionLevel y necesidad de ProfileInstallReceiver.
- Rastrear el origen de la cadena hexadecimal; tratarla como secreto y rotarla solo si es credencial real.
- Ejecutar pruebas TLS dinámicas y ampliar los flujos probados en un entorno controlado.

Fuentes y alcance

Fuentes: descarga.pdf (análisis estático), Dynamic Analysis.pdf (dinámico), vulnerabilities.md y revisión del APK. Fechas/horas copiadas como aparecen en MobSF. Este resumen no es certificación ni prueba exhaustiva.